OpenHarmony A 线 30 份报告抽查与沙箱验证

确定性分层随机抽样 · 源码与 Git 溯源核验 · 高危候选证据门 · Docker 沙箱方法验证

有效总体	抽查样本	候选复核	最终结论
378	30	345	0
份完整报告	20 有候选 + 10 零候选	高优先级 283 条	确认漏洞 / 专用 PoC

核心判断

30/30 commit、Git tree 和 snapshot 均匹配；345/345 源码哈希和引用行均匹配。没有候选同时满足真实入口、权限边界、可达敏感操作、可控触发条件和具体 CIA 影响的完整证据门，因此不制造确认漏洞或专用 PoC。

报告日期：2026-10-18

固定随机种子：20261018

抽样选择指纹：16e7da3a1fe9fda80ae66dcda856b5e776b649c0d3ce9fd40de9240ddf56a979

目录

1. 执行结论
2. 范围、假设与证据门
3. 确定性抽样与重复性
4. 源码与 Git 对象溯源
5. 候选分层与静态复核
6. Docker 沙箱与方法控制
7. 确认漏洞与 PoC
8. 改进建议
9. 局限与未知
10. 交付物与复核入口
11. 最终判断

阅读提示

报告中的“高危候选”是风险验证优先级。原扫描结果 1,645 条诊断全部为 severity=unassessed，不能据此推导漏洞等级。

- 报告日期：2026-10-18
- 抽样总体：openharmony-full-scan-20261017 中 378 份具备 report.md、result.json、run_meta.json 的有效报告
- 固定随机种子：20261018
- 样本：30 份（20 份有候选、10 份零候选）
- 抽样候选：345 条，其中风险验证高优先级 283 条、普通优先级 62 条
- 最终结论：0 个确认漏洞，0 个专用漏洞 PoC

1. 执行结论

本轮从 378 份 A 线完成报告中进行确定性分层随机抽样，复核样本内 345 条诊断，并对高危优先候选执行源码绑定、权限/入口边界、可达性、触发条件、CIA 影响和沙箱方法验证。

结论如下：

1. 30 份样本可使用固定种子和稳定排序重复得到同一组结果；抽样选择指纹为 16e7da3a1fe9fda80ae66dcda856b5e776b649c0d3ce9fd40de9240ddf56a979。
2. 30/30 commit、30/30 Git tree、30/30 snapshot SHA-256 均匹配；345/345 诊断源码哈希匹配，345/345 引用行存在，未发现源码/Git 对象不一致。
3. 扫描结果中的 1,645 条诊断在原报告中全部是 severity=unassessed。本报告中的“高危候选”表示验证优先级，不表示扫描器已经确认高危漏洞。
4. 345 条候选中，9 条判定为 not_reproduced，336 条判定为 not_testable；confirmed、dynamic_reproduced_unconfirmed 和 blocked_environment 均为 0。
5. 没有候选同时证明真实入口/权限边界、可达敏感操作、可控触发条件和具体 CIA 影响，因此不得升级为已确认漏洞，也不得制造对应 PoC。
6. Docker 沙箱、ASan/UBSan 和 TSan 方法控制均成功执行；但通用控制和缩约源码模型不等于抽样组件的产品级漏洞证明。

2. 范围、假设与证据门

2.1 范围

- 扫描总体：378 份有效报告，1,645 条诊断。
- 失败/无报告记录：按 summary.project_count=478 与 378 份有效记录对账，共 100 份不进入抽样总体。
- 磁盘另有 1 个未列入 summary.json 的部分目录 0479-third_party_selinux-4ce9dd3ea7，不进入 478 项总体。
- 本轮只生成审计和验证交付物，不修改扫描器公共 API、历史报告、候选 ID 或已有 Git 提交。
- 不访问或攻击线上服务；动态验证仅在本地 Docker 容器内进行。

2.2 高危优先候选定义

由于原扫描结果没有可信 severity 分级，本报告按潜在安全边界影响确定验证优先级：

规则	优先级	候选 CWE / 影响
ohcpp-shared-ptr-race-candidate-001	高	CWE-362；CWE-416 仅为可能后果
ipc.parcel.copy-range	高	潜在 CWE-125
ipc.auth.missing、ipc.auth.guard-coverage	高	CWE-862/863
ipc.capability.export	高	CWE-926/668
ipc.relay.descriptor-boundary	普通	边界候选，进入明细但不进入本轮重点 PoC 队列

2.3 Confirmed 证据门

候选只有同时满足以下条件才可升级为 confirmed：

1. 真实产品入口和调用者权限边界成立；
2. 可达具体敏感操作；
3. 攻击者可控且可重复的触发条件成立；
4. 具体机密性、完整性或可用性影响成立；
5. 源码、commit、tree、blob、snapshot、检测器版本和构建配置可审计绑定。

编译崩溃、sanitizer 报告、局部 AST 命中或通用 harness 触发均不能单独满足该证据门。动态触发但缺少产品入口/权限边界时，不得称为已确认漏洞。

3. 确定性抽样与重复性

3.1 抽样算法

1. 只纳入同时具备 report.md、result.json、run_meta.json 的记录。
2. 将 378 份有效记录分为 100 份有候选和 278 份零候选。
3. 对每份记录计算：

SHA-256(UTF-8(seed NUL repository NUL snapshot_sha256))

4. 按摘要十六进制值升序排序；并列时按 repository、snapshot_sha256 排序。
5. 从有候选层抽取前 20 份，从零候选层抽取前 10 份。

3.2 样本构成

指标	数量
有效总体报告	378
有候选总体报告	100
零候选总体报告	278
总体诊断	1,645
抽样报告	30
有候选样本	20
零候选样本	10
样本诊断	345
高优先级候选	283
普通优先级候选	62

样本包含 20 个仓库。候选密集样本包括 distributeddatamgr_preferences（96）、hiviewdfx_faultloggerd（55）、multimedia_camera_framework（43）、multimedia_player_framework（23）、communication_wifi（24）和 systemabilitymgr_safwk（21）。完整样本清单见 evidence/sample_manifest.json 和 Excel 的“样本与方法”页签。

3.3 重复性

构建脚本在修正排除记录计数后重新运行，选择前后指纹完全一致：

16e7da3a1fe9fda80ae66dcda856b5e776b649c0d3ce9fd40de9240ddf56a979

因此同一输入、种子和算法可重复得到同一组 30 份报告。

4. 源码与 Git 溯源

对 30 份样本和 345 条诊断执行了以下核验：

核验项	结果
commit 匹配	30/30
Git tree 匹配	30/30
snapshot SHA-256 重算匹配	30/30
诊断源码 SHA-256 匹配	345/345
引用行存在	345/345
唯一文件/哈希绑定	97
溯源错误	0

溯源验证使用本地已有 Git 对象，不 fetch、不 checkout。逐项结果见 evidence/provenance.json。任何源码、Git 对象或 snapshot 不一致都会阻止结论升级；本轮没有此类记录。

5. Docker 沙箱与动态方法验证

5.1 镜像与环境

- 验证镜像不可变 ID：sha256:e92d5365460142169ddd21d489bc9157d003c61e3382351c8f8516f3e38f96ae
- Docker Engine：29.1.3，Docker Desktop：4.55.0
- 编译器：Ubuntu clang 14.0.0
- Dockerfile：仓库现有 docker/validation/Dockerfile，未修改
- 基础镜像替代：Docker Hub 在准备阶段不可达，使用本机已有的 NVIDIA CUDA 12.2.0-base-ubuntu22.04 镜像别名为 ubuntu:22.04 后执行 docker build --pull=false。基础镜像 ID 为 sha256:00d989b22f26fca88f57a39307edaaff2ffec059333f317d95c5fdcfcc0d2117，其 RepoDigest 为 nvidia/cuda@sha256:ecdf8549dd5f12609e365217a64dedde26ecda26da8f3ff3f82def6749f53051。
- 运行约束：--network none、只读根文件系统、--cap-drop ALL、no-new-privileges、CPU 1、内存/交换 1 GiB、进程 64、CPU 时间 30 秒、文件描述符 64。
- 只有 /sandbox/out 是可写 bind mount；/tmp 为受限 tmpfs。Docker socket 未挂载。
- 为保证 sanitizer 地址映射稳定，容器内使用 setarch -R 禁用 ASLR，并相应使用 seccomp=unconfined。这是方法可重复性权衡；capabilities 仍全部移除，且保留无网络、只读根文件系统、no-new-privileges 和资源限制。

5.2 方法控制结果

控制	编译器	重放	结果
copy-range 缩约源码模型	ASan/UBSan	3	3/3 干净；非法长度拒绝，1/1024 合法长度成功
copy-range 越界阳性控制	ASan/UBSan	3	3/3 稳定报告 heap-buffer-overflow
copy-range 安全控制	ASan/UBSan	3	3/3 干净
generic shared_ptr 非原子竞争	TSan	3	3/3 稳定报告 data race
generic shared_ptr 原子修复控制	TSan	3	3/3 干净

完整 argv、环境、退出码、stdout/stderr、源码/二进制/日志哈希见 evidence/sandbox/sandbox_results.json、evidence/sandbox/scratch/ 和 evidence/sandbox/sandbox_file_hashes.json。

5.3 解释边界

- copy-range 模型是源码派生缩约模型，用于核对 guard 和容量关系，不是完整产品构建。
- generic shared_ptr 控制只说明 TSan 方法能检测非原子竞争，不证明任何抽样组件存在竞争。
- 本轮没有把通用控制放入 poc/<finding-id>/，也没有将其冒充抽样组件证明。

6. 候选复核结果

6.1 汇总

规则	高危优先	数量	confirmed	not_reproduced	not_testable
ohcpp-shared-ptr-race-candidate-001	是	263	0	0	263
ipc.parcel.copy-range	是	1	0	1	0
ipc.capability.export	是	14	0	8	6
ipc.auth.missing / ipc.auth.guard-coverage	是	5	0	0	5
ipc.relay.descriptor-boundary	否	62	0	0	62
合计		345	0	9	336

状态定义：

- confirmed：完整证据门成立。本轮 0 条。
- dynamic_reproduced_unconfirmed：动态触发但产品可达性/影响未闭合。本轮 0 条。
- not_reproduced：源码或可重复缩约验证未复现所声称问题。本轮 9 条。
- not_testable：缺少目标构建、并发交错、权限策略或产品级 harness，无法安全测试。本轮 336 条。
- blocked_environment：环境阻塞。本轮 0 条。

6.2 ipc.parcel.copy-range：1 条

- 组件：communication_wifi
- 位置：wifi/frameworks/native/src/wifi_p2p_callback_stub.cpp:385
- 候选：潜在 CWE-125
- 最终状态：not_reproduced

源码证据显示：

```
if (cfgLen <= 0) return;
if (cfgLen > MAX_LEN) return; // MAX_LEN = 1024
dataBuffer = data.ReadBuffer(cfgLen);
cfgData = new char[cfgLen];
memcpy_s(cfgData, cfgLen, dataBuffer, cfgLen);
```

扫描器的 guard 匹配没有识别有效的下界和上界。目标容量与拷贝长度一致，且两个缓冲区均受 cfgLen 约束。Docker 中的源码派生缩约模型对 -2147483648、-1、0、1025、2147483647 等非法长度均拒绝，对 1 和 1024 合法长度正常完成，3 次 ASan/UBSan 重放均无发现；越界阳性控制稳定触发，安全控制稳定干净。

该结果证明扫描命中很可能是 guard 识别误报，但不等同上游代码已经完成完整安全审计。剩余证明义务是：若继续主张 CWE-125，需要给出绕过两层长度 guard 的产品级触发路径和 CIA 影响。

6.3 ohcpp-shared-ptr-race-candidate-001：263 条

候选跨 16 个仓库，大多数是成员声明、初始化、容器插入或局部 shared_ptr 读写语法。缺少：

- 方法级别名和所有权转移；
- 真实并发交错和析构时序；
- 锁/原子操作的 guard dominance；
- 攻击者可控线程调度；
- 完整目标构建配置；
- 从竞争到 UAF 或其他 CIA 影响的产品级证据。

generic TSan 阳性/固定控制可重复工作，但不能绑定到这些组件，因此 263 条均保持 not_testable，不升级、不制作 PoC。

6.4 ipc.capability.export：14 条

1. distributeddatamgr_data_share：2 条 WriteFileDescriptor 候选位于 OpenFile/OpenFileWithErrCode。局部 Stub 片段未展示授权，但 provider 抽象内部可能执行 URI/mode 授权。证据链未闭合，状态 not_testable。
2. systemabilitymgr_samgr：8 条生产候选的导出前可见 CheckGetSAPermission、CheckGetRemoteSAPermission、用户/远端检查或 PengLai/权限 guard。扫描器未将 guard 归一化，属于强 guard-dominance 误报证据，状态 not_reproduced。
3. systemabilitymgr_samgr：2 条位于 test/unittest，不属于产品暴露面，状态 not_testable，理由 out_of_scope_test_code。
4. ai_intelligent_voice_framework：CreateEngineInner 返回 engine->AsObject() 看起来是预期服务 API，未证明对象越过授权 owner 边界，状态 not_testable。
5. communication_wifi：GetWifiRemoteInner 在 interface token dispatch 后返回服务 remote object，未证明未授权 capability 泄露，状态 not_testable。

6.5 ipc.auth.*：5 条

1. distributeddatamgr_data_share::OpenFileInner：可能由 OpenFile provider 实现执行授权，局部函数不能证明缺失，状态 not_testable。
2. systemabilitymgr_safwk::StartAbilityInner：有输入校验，但 caller privilege boundary 和上游 ability policy 未完整绑定，状态 not_testable。
3. systemabilitymgr_safwk 测试探针：产品范围外，状态 not_testable。
4. multimedia_camera_framework::CreateCameraDevice：源码显式区分 isPrivilegeApp 与非特权处理。扫描路径不是未授权访问证明，但由于完整调用者/策略链未闭合，保持 not_testable。

这些候选均缺少真实未授权调用者绕过策略并产生 CIA 影响的证据。

6.6 ipc.relay.descriptor-boundary：62 条

62 条候选分布于通信、多媒体、相机、SA 框架、企业设备管理等组件。它们已进入样本明细和源码溯源，但本轮为普通优先级，不进入重点 PoC 队列。由于没有完整的 descriptor 解析边界、目标容量、入口权限和 CIA 数据流，统一保持 not_testable，不计入确认漏洞。

7. 确认漏洞与 PoC

确认漏洞：0。专用 PoC：0。

poc/README.md 和 poc/index.json 明确记录零确认漏洞。没有创建伪造的 poc/<finding-id>/ 目录。若后续候选通过完整证据门，PoC 至少应包含：

- 源码绑定 manifest；
- harness 和完整运行命令；
- 攻击、固定和安全对照；
- 每个攻击用例至少 3 次稳定性重放；
- sanitizer 输出、退出码、随机性和重复性；
- 修复补丁变体的补丁前后重验；
- 受影响模块/版本/分支与 CIA 影响。

8. 改进建议

8.1 产品侧

1. 授权边界显式化：DataShare、Safwk、Camera 等在公共 IPC 入口统一执行 caller 权限校验，避免授权隐含在 provider/抽象内部。
2. 能力导出最小化：SAMGR、WiFi、IntellVoice 对导出 remote object/FD 的 owner、允许调用者和生命周期建立显式策略与审计日志。
3. 并发所有权治理：共享 shared_ptr 统一使用 mutex、atomic<std::shared_ptr> 或明确的不可变所有权转移；禁止未同步的多线程读写。
4. 边界复制统一 API：为 Parcel-derived 长度集中提供 checked length、checked allocation 和 checked copy helper，并在编译期/测试中验证 guard。
5. 测试与产品隔离：测试探针不应进入产品 capability/auth 审计统计，除非其链接到真实产品入口。
6. 回归控制：为 guard dominance、权限校验和并发同步补充 positive/fixed/safe/unrelated 控制。

8.2 扫描器侧

1. 权限/入口建模：解析 Binder/IPC dispatch code、interface token、UID/PID、权限声明和调用者域。
2. Guard dominance：识别 <=0、>MAX、nullptr、返回码和跨函数 provider guard，避免把有效 guard 当缺失。
3. 原子性与生命周期证明：对 shared_ptr 建立方法级 alias/ownership、并发访问集合、析构时序和同步原语证明。
4. 目标构建配置：绑定编译器、宏、ABI、线程模型、目标库和构建产物；没有完整构建时不生成动态确认。
5. 候选聚类：按 root cause、文件/符号、入口和 guard 合并重复候选，避免 263 条语法噪声掩盖 9 条重点复核结果。
6. 动态 harness 自动生成：从目标源码、入口和数据流生成 harness，并强制攻击/固定/安全对照与稳定性重放。
7. 风险优先级与漏洞定级分离：候选规则只产生验证优先级；severity/confirmed 必须由证据门和人工/动态复核决定。
8. 可审计输出：输出源码/Git/snapshot/hash、检测器版本、scope/profile、完整 argv/env 和 sanitizer 日志哈希。

9. 局限与未知

1. 本轮没有完整构建 OpenHarmony 产品镜像；动态部分是源码派生缩约模型和通用控制，不是产品 PoC。
2. 336 条 not_testable 的主要原因是缺少完整权限策略、目标构建、并发交错或产品级 harness；这不是“安全”结论。

3. SAMGR 8 条 not_reproduced 是基于可见 guard 的静态反证；若存在未展示的绕过分支，仍需产品级动态复核。
4. 基础镜像因 Docker Hub 不可达采用本地 NVIDIA CUDA Ubuntu 22.04 镜像替代；最终验证镜像由不可变 ID 固定，但严格可重建发布仍应归档镜像和构建上下文。
5. 为 sanitizer 地址映射稳定而使用 seccomp=unconfined，虽然保留了无网络、只读根文件系统、cap-drop ALL、no-new-privileges 和资源限制，但严格生产沙箱可进一步使用定制 seccomp profile。
6. 本轮不计算 Precision/Recall，因为没有独立、合适的标注数据。

10. 交付物与复核入口

交付物	说明
evidence/sample_manifest.json	30 份样本、算法、计数和逐条诊断
evidence/sample_reproducibility.json	固定选择指纹与重复运行一致性
evidence/provenance.json	commit/tree/snapshot/source hash/line 核验
evidence/candidate_reviews.json	345 条逐条静态/动态/义务/状态
evidence/environment.json	Docker、镜像、基础替代、编译器和限制
evidence/sandbox/	沙箱控制源码、原始日志、退出码和哈希
poc/README.md、poc/index.json	0 个确认漏洞、0 个专用 PoC
openharmony-a-line-sample30.xlsx	低认知负担四页签工作簿
report/technical-report.pdf	本报告的评审版 PDF

11. 最终判断

本轮抽样、溯源、候选复核和沙箱方法验证均已完成。当前证据不支持任何“确认漏洞”结论；正确交付是 0 个确认漏洞、0 个漏洞 PoC。对高危候选应继续补齐权限边界、目标构建和产品级动态证据，但不得用扫描命中、通用控制或缩约模型替代真实漏洞证明。